KEMENTERIAN PENDIDIKAN, TINGGI,
SAINS, DAN TEKNOLOGI
POLITEKNIK NEGERI BENGKALIS
Jalan Bathin Alam, Sungai Alam, Bengkalis, Riau 28711
Telepon: (+62766) 24566 | Fax: (+62766) 800 1000
Laman: http://www.polbeng.ac.id | E-mail:
polbeng@polbeng.ac.id

DOKUMEN PERENCANAAN PENGUJIAN PENETRASI

Mata Kuliah Penetration Testing Semester 5

Nama Mahasiswa	M. Arifin Ilham
NIM	6404240008
Mata Kuliah	Penetration Testing
Program Studi	Sarjana Terapan Keamanan Sistem Informasi
Dosen Pengampu	Nurmi Hidayasari
Target Pengujian	nyamankos — https://nyamankos.ours.web.id
Rujukan RoE	RoE Pentest KSI 5A 2026 — ditandatangani 25/09/2026
Tanggal Penyusunan	01 Oktober 2026
Kerangka Kerja	PTES (Penetration Testing Execution Standard) — 7 fase

1. Pre-Engagement Interactions

Fase ini disesuaikan dengan RoE yang sudah ditandatangani. Tidak menuliskan ulang dari sumber lain.

Tujuan Pengujian	Mengidentifikasi kerentanan kategori OWASP Top 10 pada aplikasi nyamankos (https://nyamankos.ours.web.id) sebelum sistem diserahterimakan kepada mitra, sekaligus memenuhi capaian pembelajaran Mata Kuliah Penetration Testing sesuai RPS.
Ruang Lingkup	HANYA lapisan aplikasi web (HTTP/HTTPS). Tidak mencakup lapisan jaringan/infrastruktur/server. (Dikutip dari RoE Bagian 4) Kategori yang tercakup: • Input validation & injection (SQL Injection, XSS, command injection) • Autentikasi & manajemen sesi • Otorisasi & kontrol akses (IDOR, privilege escalation tingkat akun) • Konfigurasi keamanan dari luar (security header, endpoint/berkas terekspos) • Alur bisnis dan logika aplikasi
Batasan (Exclusion)	• Port scanning / pemindaian jaringan apapun terhadap target (termasuk Nmap) — DILARANG MUTLAK • Eksploitasi lanjutan level OS/server setelah dapat akses shell — DIHENTIKAN & dilaporkan • Aksi destruktif ireversibel: menghapus/mengubah data permanen • Social engineering terhadap pihak di luar penanda tangan RoE • Menyebarluaskan data/kredensial di luar keperluan akademik (Dikutip dari RoE Bagian 5)
Jadwal Keseluruhan	Minggu 3 s.d. Minggu 12, mengikuti jadwal praktikum mata kuliah. (Dikutip dari RoE Bagian 8)
Kontak Eskalasi	Dosen Pengampu : Nurmi Hidayasari (0811-7500-891) Tim Pengembang : Revis Irwan Gea (0812-6534-2848) (Dikutip dari RoE Bagian 6)

2. Intelligence Gathering

Teknik bersifat pasif/berbasis HTTP publik — tidak menyentuh port di luar 80/443.

Teknik yang direncanakan:

- **[✓]** WHOIS / pencarian registrasi domain
- **[✓]** DNS lookup (dig/nslookup) — terbatas, tanpa port scan
- **[✓]** Google dorking (site:nyamankos.ours.web.id)
- **[✓]** Pemeriksaan header HTTP (curl -I / curl -v)
- **[✓]** Deteksi teknologi (WhatWeb / Wappalyzer)
- **[✓]** Pemeriksaan robots.txt dan sitemap.xml
- **[✓]** Inspeksi DevTools browser (source JS, cookies, network tab)
- **[☐]** Lainnya: —

Sumber informasi yang ditargetkan:

- Teknologi stack (framework, versi CMS, server header)
- Endpoint/path tersembunyi yang tidak sengaja terekspos
- Informasi kontak publik, subdomain, dan metadata
- Cookie flags, security header (X-Frame-Options, CSP, HSTS, dll.)

Estimasi Waktu : 2–3 jam (Minggu 5)

3. Threat Modeling

Identifikasi fitur/aset yang paling bernilai atau berisiko untuk diprioritaskan pengujiannya.

Fitur / Aset	Alasan Prioritas	Prioritas
Form Login / Autentikasi	Pintu masuk utama; rentan terhadap brute force, SQL Injection, bypass	T
Form Pendaftaran/Registrasi	Rentan injeksi data, Stored XSS, dan validasi input lemah	T
Halaman Pencarian Kos	Parameter URL rentan SQL Injection & Reflected XSS	T
Manajemen Profil Pengguna	Rentan IDOR — akses data pengguna lain dengan manipulasi parameter id	T
Panel Admin (jika ada)	Eskalasi privilege; akses tidak terotorisasi ke fitur administratif	T
Proses Booking/Pemesanan	Business Logic — manipulasi harga/kuantitas untuk bypass validasi	S
Endpoint API / AJAX	Bisa terekspos data sensitif tanpa autentikasi	S
Halaman Ulasan/Komentar	Rentan Stored XSS yang memengaruhi pengguna lain	S

Prioritas: T = Tinggi | S = Sedang | R = Rendah

4. Vulnerability Analysis

4.1 Scanning

Kategori OWASP WSTG yang ditargetkan:

- **[✓]** Information Gathering
- **[✓]** Configuration and Deployment Management Testing
- **[✓]** Identity Management Testing
- **[✓]** Authentication Testing
- **[✓]** Authorization Testing
- **[✓]** Session Management Testing
- **[✓]** Input Validation Testing (SQL Injection, XSS, dsb.)
- **[✓]** Error Handling & Cryptography
- **[✓]** Business Logic Testing
- **[☐]** Client-Side Testing

Metode scanning yang dipakai:

- **[☐]** Automated scanning penuh (OpenVAS/Nessus)
- **[✓]** Active Scan berbasis HTTP (Burp Suite Scanner / OWASP ZAP Active Scan)
- **[✓]** Manual testing per test case WSTG (tanpa tools otomatis)

Tools yang dipakai:

- Burp Suite Community (intercepting proxy, Repeater, Intruder)
- OWASP ZAP (Active Scan mode HTTP)
- curl (pemeriksaan header HTTP)
- WhatWeb (deteksi teknologi)
- Browser DevTools (inspeksi request, cookie, source)

Tools yang TIDAK dipakai (batasan RoE): Nmap, Nessus/OpenVAS terhadap target nyata, dan semua tools pemindai jaringan/infrastruktur.

4.2 Assessment (Verifikasi Temuan)

Setiap temuan dari scanning wajib diverifikasi secara manual sebelum dianggap kerentanan yang sah.

Temuan Scanner	Kategori WSTG	Verifikasi Manual	CVE/CWE
(diisi setelah scanning dijalankan)	*(kategori)*	*[Confirmed / False Positive]*	*[mis. CWE-89]*
(diisi setelah scanning dijalankan)	*(kategori)*	*[Confirmed / False Positive]*	*[mis. CWE-79]*
(diisi setelah scanning dijalankan)	*(kategori)*	*[Confirmed / False Positive]*	*[mis. CWE-287]*

Baris di atas diisi setelah scanning benar-benar dijalankan — pada tahap perencanaan ini, format tabel sudah disiapkan.

5. Exploitation

Serangan/teknik eksploitasi yang direncanakan, per kategori kerentanan yang dikonfirmasi pada Bagian 4.

Kategori Kerentanan	Teknik / Payload Contoh	Tools
SQL Injection	UNION-based / boolean-based blind pada parameter id atau search	sqlmap, Burp Repeater
Cross-Site Scripting (XSS)	Reflected XSS via parameter pencarian Payload: <script>alert(document.cookie)</script>	Burp Suite, payload manual
Broken Authentication	Uji daftar kredensial umum pada form login secara terbatas (rate-limited, bukan brute force penuh)	Burp Intruder (terbatas), pengujian manual
Broken Access Control / IDOR	Ubah parameter id (user_id, booking_id) pada URL/request untuk mengakses data akun lain	Burp Suite Repeater, parameter tampering manual
Session Management	Uji apakah token sesi tetap valid setelah logout; apakah token dapat ditebak/diprediksi	Burp Suite (cookie/token inspection)
Business Logic	Manipulasi nilai harga/kuantitas saat proses booking (mis. kuantitas negatif) untuk uji validasi server	Burp Suite Repeater, pengujian manual

Tools eksploitasi yang dipakai:

- **[✓]** sqlmap
- **[✓]** Burp Suite Intruder/Repeater
- **[✓]** OWASP ZAP (manual attack mode)
- **[✓]** Payload/skrip kustom (XSS payload, IDOR parameter tampering)
- **[☐]** Lainnya: —

Kriteria temuan tervalidasi: Berhasil mengeksekusi payload dan mengonfirmasi dampaknya secara nyata (data terekspos, sesi terbajak, atau akses tidak terotorisasi terbukti).

⛔ **Kriteria BERHENTI (wajib, tidak dapat diubah):** Begitu suatu command injection atau kerentanan lain terbukti memberi akses tingkat OS/server, aktivitas pada temuan tersebut DIHENTIKAN dan segera dilaporkan sesuai prosedur eskalasi RoE — tidak dieksplorasi lebih lanjut.

6. Post-Exploitation

Penilaian dampak dilakukan melalui analisis, bukan dengan melakukan aktivitas lanjutan yang melampaui exclusion list RoE (mis. lateral movement, akses ke sistem lain).

Jenis data yang berpotensi terekspos:

- Data pribadi pengguna (nama, alamat, nomor telepon, email)
- Data kredensial (username/password hash)
- Data transaksi/booking kos
- Informasi internal aplikasi (struktur database, path server dari pesan error)

Dampak bisnis jika dieksploitasi pihak luar:

- Kebocoran data pengguna → pelanggaran privasi dan kepercayaan
- Manipulasi data booking → kerugian finansial dan operasional
- Eskalasi akses admin → kendali penuh atas sistem
- Downtime aplikasi → gangguan layanan mitra

7. Reporting

Struktur laporan akhir yang akan diikuti:

- Ringkasan Eksekutif
- Metodologi (rujuk kerangka PTES ini)
- Temuan per kategori WSTG, lengkap dengan tingkat risiko (CVSS) dan bukti
- Rekomendasi mitigasi

Kriteria keberhasilan pelaporan: Seluruh kategori WSTG yang ditargetkan pada Bagian 4 telah diuji dan dilaporkan, terlepas dari jumlah temuan yang ditemukan.

8. Rencana Kerja Mingguan

Memetakan aktivitas per minggu, termasuk lingkungan yang dipakai (Real/Dummy) sesuai batasan RoE.

Mg	Fase PTES	Aktivitas	Lingkungan
5	Intelligence Gathering	WHOIS, DNS lookup pasif, Google dorking, curl header check, WhatWeb, robots.txt, DevTools	**Real**
6	Intelligence Gathering	Nmap: host discovery, port scan, OS fingerprint — target nyata TIDAK disentuh	**Dummy**
7	Vulnerability Analysis (Scanning)	OpenVAS/Nessus full scan → Dummy; Burp Suite/ZAP Active Scan HTTP → Real	**Kedua**
9	Vuln. Analysis & Exploitation (awal)	Verifikasi temuan manual per WSTG; Eksploitasi app-layer → Real; Kill-chain penuh → Dummy	**Kedua**
10–12	Exploitation (lanjutan)	OWASP Top 10/WSTG: SQL Injection, XSS, autentikasi, kontrol akses, IDOR, Business Logic, Session Mgmt	**Real**
13	Post-Exploitation	Cek TLS/cipher (testssl.sh) → Real; Baseline hardening & open port → Dummy; Analisis dampak temuan	**Kedua**
14	Reporting	Penyusunan laporan: Ringkasan Eksekutif, Metodologi, Temuan & Bukti, CVSS rating	—
15	Reporting (Final)	Finalisasi laporan, rekomendasi mitigasi, persiapan & presentasi akhir	—

9. Persetujuan

Dengan menandatangani dokumen ini, dosen pengampu menyatakan telah memverifikasi kesesuaian rencana ini dengan RoE yang berlaku. (Lampirkan RoE yang sudah ditandatangani.)

Mahasiswa	**Dosen Pengampu**
	
(_____)	(_____)
M. Arifin Ilham	Nama: Nurmi Hidayasari
NIM: 6404240008	Tanggal:
Tanggal: 01 Oktober 2026	

Catatan: